UNIVERSITY OF LONDON

BSc EXAMINATION 2024

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3660: Applications of Cryptography

Time Allowed: **TWO hours**

Answer **THREE** questions
No credit will be given for attempting any further questions

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

©Royal Holloway, University of London 2024

Question 1

(a) Give a definition for a block cipher with key length k and block size n. [4 marks]

(b) Name **TWO** approaches for constructing an iterative block cipher and, for each approach, give **ONE** example of a block cipher constructed in this way. [4 marks]

(c) What does it mean for a block cipher to be PRP secure? [4 marks]

(d) Suppose that many ciphertext blocks of a 128-bit PRP-secure block cipher are generated when using this block cipher in CBC mode. After how many blocks generated this way would you expect to see such repeats? Explain your reasoning. [6 marks]

(e) Let E_K be a block cipher that operates on 128-bit blocks. Suppose that a repeated ciphertext block is found when using E_K in CBC mode, i.e., the blocks C_i and C_j are equal. Suppose the corresponding plaintext blocks are P_i and P_j, and further suppose that P_i is known. Show how P_j can be recovered. [7 marks]

(f) Let E be a block cipher operating on 4-bit blocks. Let K be a key, such that encryption with E under K is given by the table below.

$0000 \mapsto 1100$	$0100 \mapsto 1001$	$1000 \mapsto 0011$	$1100 \mapsto 0111$
$0001 \mapsto 0101$	$0101 \mapsto 1010$	$1001 \mapsto 1110$	$1101 \mapsto 0100$
$0010 \mapsto 0110$	$0110 \mapsto 0000$	$1010 \mapsto 1000$	$1110 \mapsto 0001$
$0011 \mapsto 1011$	$0111 \mapsto 1101$	$1011 \mapsto 1111$	$1111 \mapsto 0010$

For example, $E_K(0000) = 1100$. Likewise, the decryption of 0010 is given by $D_K(0010) = E_K^{-1}(0010) = 1111$.

(i) Encrypt the following 17-bit message M with E_K using ECB mode

$$M = 1011\ \ 0101\ \ 1001\ \ 0111\ \ 0$$

to obtain the ciphertext C. If padding is needed, then append M with zeros (as few as possible). [3 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(ii) Encrypt the following 13-bit message M' with E_K using CTR mode

$$M' = \texttt{0110 1100 1101 1},$$

to obtain the ciphertext C'. For the counter, use $\texttt{0000}$, $\texttt{0001}$, $\texttt{0010}$, etc. If padding is needed, then append M' with zeros (as few as possible).

[3 marks]

(g) Explain why the padding approach proposed in part (f) would be unsuitable in a practical application. [3 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2

(a) Define the following security properties of a cryptographic hash function H:

(i) Collision resistance [2 marks]

(ii) Second pre-image resistance [2 marks]

(b) Give an argument to show that a collision resistant hash function H must also be second pre-image resistant. [6 marks]

(c) The Merkle-Damgård construction is a popular method of building an n-bit hash function H from a compression function $h : \{0,1\}^{n+k} \to \{0,1\}^n$.

(i) Show how the Merkle-Damgård construction uses h to compute the hash value $H(m)$ of a message $m \in \{0,1\}^*$. You may use a diagram to illustrate your answer. [5 marks]

(ii) Consider a key derivation function (KDF) that is constructed from a Merkle-Damgård hash function H. The KDF derives each new key K_i using an n-bit master key $K \in \{0,1\}^n$, i k-bit identifiers $x_i \in \{0,1\}^k$, and H, as $K_i = H(K||x_1||\ldots||x_i)$. For example, $K_1 = H(K||x_1)$ and $K_2 = H(K||x_1||x_2)$. The head of IT in an organisation holds the master key K and uses this KDF to issue a different key K_i to each employee in the organisation, using employee numbers (that are known to everyone) as the identifiers x_i. The head of IT argues that one employee cannot learn the key of another employee without finding a pre-image of H and thereby recovering the master key K. They conclude this application of the KDF is secure. Do you agree with this argument? Explain your answer. [6 marks]

(d) Give a definition for a Message Authentication Code (MAC) with key length k and tag length t. [3 marks]

(e) State the correctness requirement for a MAC. [3 marks]

(f) HMAC is a popular MAC constructed from a hash function. Under a suitable assumption about the compression function, summarise what is meant by

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

the statement that HMAC is SUF-CMA secure, making clear the meanings of the terms SUF and CMA. [7 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3

The board of the company BizCorpInc is considering a proposal to equip its staff with secure communications facilities and requires your help to evaluate it.

In the proposed deployment, each staff member at BizCorpInc will be issued with a smart-card that stores a long-term Diffie-Hellman private key x and a long-term Diffie-Hellman public key $g^x \bmod p$. Here $p = kq + 1$, and g generates G_q, a cyclic group of prime order q in the set of integers modulo the prime p; that is, $G_q = \{g^0 = 1, g^1, g^2, \ldots, g^{q-1}\}$. All smart-cards will use the same parameters (p, q, g). When given another person's public key $g^y \bmod p$ as input, the smart-card will use its stored private key to compute and output the shared Diffie-Hellman key $K = g^{xy} \bmod p$.

This key K will be used as the key in a symmetric encryption scheme that will protect messages sent between BizCorpInc staff. Each staff member will be given a smart-card reader that plugs into their computer, so the computer can interact with smart-cards. Encryption and decryption using the symmetric scheme will be performed using a secure messaging application installed on the computer. Some BizCorpInc staff work remotely, so their computers will also be used to send and receive messages over the Internet. As all the long-term keys are stored on the smart-cards, it was deemed unnecessary to authenticate the public keys.

The board of BizCorpInc have hired you to write a report on the cryptographic aspects of this proposed system. **Your task is to produce that report**.

Your report may cover any cryptographic aspect of the proposal. This could include the following: the appropriate selection of the parameters (p, q, g); the lifecycle of keys in the system; the potential for attacks on the system; the choice not to authenticate public keys; the selection of a suitable symmetric encryption scheme; alternative cryptographic solutions. Other cryptographic aspects may be addressed in your report, and will be credited as appropriate. [34 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4

(a) One main purpose of the TLS Handshake Protocol is to establish shared keying material for subsequent use in the TLS Record Protocol. State two other purposes of the TLS Handshake Protocol. [4 marks]

(b) One approach for establishing keys in the TLS Handshake Protocol involves an ephemeral Diffie-Hellman key exchange where an RSA-based signature is used to sign the Diffie-Hellman parameters and client nonces. Let the verification key be $\mathtt{vk} = (N, e)$ and the signing key be $\mathtt{sk} = d$, where $N = pq$ is a product of two large primes and $ed = 1 \mod (p-1)(q-1)$. In a naive implementation of an RSA-based signature, the Sign algorithm on input a message m and signing key $\mathtt{sk}$ outputs the signature $\sigma = m^d \mod N$.

(i) Briefly outline the purpose of the RSA-based signature within this TLS Handshake Protocol and how it achieves that purpose. [4 marks]

(ii) State the Verify algorithm for the naive scheme. [2 marks]

(iii) Show how signatures can be forged in the naive scheme. [4 marks]

(iv) Show how the naive scheme can be altered using a full-domain hash function H to prevent such forgeries. [2 marks]

(v) Would you recommend the full-domain hash variant in part (iv) be used in the TLS Handshake Protocol? Justify your answer. [2 marks]

(c) Another approach for establishing keys in the TLS Handshake Protocol uses RSA-based public key encryption, where the server possesses a long-term RSA key pair.

(i) Give a high level summary of how the client and server would establish a shared key in this way. [3 marks]

(ii) Define the term forward secrecy. [2 marks]

(iii) Explain why this approach does not offer forward secrecy. [3 marks]

(iv) As this approach does not offer forward secrecy, it is no longer supported in TLS 1.3. Identify one other difference between TLS 1.2 and TLS 1.3. [2 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(d) Consider a possible future in which a large scale quantum computer is built.

(i) Explain why using RSA-based approaches within the TLS protocol would be insecure in this situation. [4 marks]

(ii) How could TLS be adapted to remedy this insecurity? [2 marks]

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.